

Cyber Tabletop Exercise

Medical Imaging Malware Disruption

Metro Regional Hospital • Radiology Imaging Network
Facilitation-ready exercise package

Exercise type	Discussion-based tabletop exercise
Sector	Healthcare / hospital operations
Primary impacted service	Radiology imaging: CT, MRI, X-ray workflows and PACS access
Threat scenario	Malicious attachment leads to malware disruption across weakly segmented clinical systems
Recommended duration	90 minutes, including opening and final debrief
Audience	Executive crisis cell, clinical operations, IT, SOC/IR, privacy/legal, communications, facilities/biomedical engineering

Confidential exercise material. For internal planning, facilitation, and authorized distribution only.

1. Introduction

This tabletop exercise places hospital crisis, clinical, and technical teams into a realistic cyber disruption affecting medical imaging services. The scenario starts with a user opening a malicious attachment and escalates into malware-driven instability across radiology workstations and PACS access. Participants must make decisions under operational uncertainty while protecting patient safety, preserving evidence, restoring services, and managing communications.

The scenario is fictional, but the decisions, escalation pathways, and clinical impacts are designed to mirror real hospital incident-management conditions.

Source Intelligence Summary

STIX element	Exercise interpretation
Victim organization	Metro Regional Hospital
Impacted infrastructure	Radiology Imaging Network: Clinical imaging systems supporting CT, MRI, and X-ray workflows.
Threat actor	Healthcare Intrusion Operator (crime-syndicate)
Malware	MedLock Loader: Malware used to disrupt clinical workstations and spread through poorly segmented hospital networks.
Initial access pattern	User Execution of Malicious Attachment (T1204)
Incident	Medical Imaging Malware Disruption: Malware disrupts hospital imaging services and affects patient care operations.

2. Exercise Scope and Assumptions

- The exercise focuses on decision-making, escalation, communications, patient-care continuity, and safe technical containment; it is not a technical hunt lab.
- The hospital has a centralized SOC or managed detection function, an incident-response process, and established clinical downtime procedures.
- Radiology imaging services are clinically critical for emergency, trauma, inpatient, and surgical workflows.
- PACS viewer instability is considered a patient-care risk, even before full malware scope is confirmed.
- Participants should avoid debating whether the scenario could occur and instead respond according to their roles, policies, and judgment.

Out of Scope

- Hands-on malware reverse engineering.
- Live changes to production networks or clinical systems.
- Blame attribution for individual staff members.
- Detailed legal advice; privacy and regulatory questions should identify required escalation and decision criteria.

3. Exercise Objectives

- Validate escalation from suspicious endpoint activity to operational crisis management and executive decision-making.

- Test coordination between SOC/IR, IT infrastructure, radiology operations, emergency department leadership, privacy/legal, communications, and executive leadership.
- Assess patient-care continuity decisions, including manual workflows, imaging prioritization, and diversion thresholds.
- Clarify technical containment authority for isolating clinical imaging networks while maintaining safe care delivery.
- Practice internal and external communications with clinicians, patients, partner hospitals, vendors, and regulators.
- Identify gaps in segmentation, privileged access, endpoint visibility, downtime readiness, and restoration governance.

Audience-Specific Focus

Audience	Primary decisions to exercise
Executive / Crisis Cell	Escalation, patient safety risk appetite, external communications, diversion approval, regulatory posture, recovery prioritization.
Clinical Operations	Imaging triage, downtime workflows, patient safety monitoring, ED and surgical coordination, clinician communications.
SOC / IR / IT	Evidence preservation, host containment, segmentation, restoration sequencing, reconnection criteria, vendor coordination.
Privacy / Legal / Compliance	Breach assessment, notification thresholds, documentation quality, regulator and law-enforcement engagement criteria.
Communications	Staff messages, patient-facing updates, media holding statements, reputational-risk management.

4. Rules of Engagement

- Real incidents and patient-care obligations take priority.
- There are no right or wrong answers; the goal is to identify strengths, gaps, and decision criteria.
- Participants should speak from their actual roles and responsibilities.
- Use existing policies, playbooks, and escalation channels where available.
- Facilitators may introduce ambiguity; participants should document assumptions and decision triggers.
- Do not fight the scenario: treat the information provided in each inject as true for exercise purposes.

5. Scenario Narrative

On a weekday morning, a radiology scheduling clerk opens what appears to be a routine invoice attachment. Endpoint monitoring soon detects suspicious PowerShell activity on the clerk's workstation. Within hours, CT and MRI workstations begin rebooting unexpectedly, and clinicians report intermittent inability to retrieve imaging results through the PACS viewer. Security analysts later confirm malware on systems connected to the radiology imaging network. Early evidence suggests that network segmentation gaps may have allowed the malware to spread from administrative systems into clinical imaging environments.

As uncertainty grows, emergency department leadership considers diverting trauma patients because urgent imaging availability is unreliable. The organization must coordinate containment, patient-safety procedures, communications, restoration, and regulatory documentation while maintaining clinical operations.

6. Exercise Timeline

Time	Inject	Exercise emphasis
------	--------	-------------------

T+0:00	Suspicious workstation activity	Triage, escalation, endpoint containment, communications to radiology leadership.
T+1:30	Imaging workflow disruption	Clinical impact assessment, downtime procedures, service prioritization.
T+3:00	Malware confirmed	Incident severity, segmentation, isolation, evidence preservation, executive escalation.
T+5:00	Patient care escalation	Diversion decision, patient safety governance, external communications, recovery priorities.
T+24–72h	Stabilization and debrief	Restoration criteria, post-incident reporting, lessons learned, corrective actions.

Inject 1: Suspicious Workstation Activity

Time	Situation update
T+0:00 / 08:15	A radiology scheduling clerk reports opening an invoice attachment. Endpoint monitoring detects suspicious PowerShell activity on the workstation.

Discussion Questions

- Who receives this alert first, and what information is needed to determine severity?
- Should the workstation be isolated immediately? Who has authority to make that decision?
- Which clinical or operational leaders need to be informed at this stage?
- What evidence must be preserved before reimaging or removing the workstation?
- How do you determine whether the activity is limited to one user or part of a broader campaign?

Expected Actions / Good Practice Indicators

- Open or update incident ticket; classify preliminary severity.
- Contain the endpoint while preserving logs and volatile evidence where feasible.
- Notify SOC/IR lead, IT operations, radiology operations manager, and help desk leadership.
- Collect email attachment, sender metadata, endpoint telemetry, PowerShell command history, EDR alerts, user activity timeline.
- Initiate phishing/malware triage and search for similar messages or executions.

Facilitator Notes

Push participants to separate technical containment from business-impact escalation. Watch for unclear authority between help desk, SOC, and clinical operations.

Inject 2: Imaging Workflow Disruption

Time	Situation update
T+1:30 / 09:45	CT and MRI workstations begin rebooting unexpectedly. Clinicians cannot reliably access imaging results through the PACS viewer.

Discussion Questions

- Which clinical workflows are immediately affected by CT/MRI instability and PACS access issues?
- Who decides whether radiology downtime procedures are activated?
- How are urgent studies prioritized and communicated across ED, ICU, surgery, and inpatient units?
- What temporary workflows exist for image acquisition, reading, result communication, and documentation?
- What internal message should be sent to clinicians to prevent unsafe workarounds?

Expected Actions / Good Practice Indicators

- Activate radiology and hospital downtime procedures based on impact threshold.
- Establish clinical command link between radiology, ED, nursing, surgery, bed management, and incident command.
- Prioritize trauma, stroke, critical care, and time-sensitive imaging studies.
- Use approved manual ordering/result workflows and document deviations from normal process.

- Track patient safety risks and near misses in an incident log.

Facilitator Notes

Press for concrete continuity actions, not generic 'communicate more'. Ask who owns the patient-safety risk decision and how decisions are documented.

Inject 3: Malware Confirmed

Time	Situation update
T+3:00 / 11:15	Security analysts confirm malware on systems connected to the radiology imaging network. Network segmentation gaps may have allowed spread from administrative systems.

Discussion Questions

- Does this meet the threshold for cyber incident escalation or crisis-cell activation?
- Should administrative-to-radiology connectivity be restricted immediately?
- What services must remain connected to preserve safe patient care?
- How will IT validate segmentation gaps and prevent further spread without causing additional clinical harm?
- What vendor, biomedical engineering, and PACS support contacts are needed?

Expected Actions / Good Practice Indicators

- Escalate to cyber incident commander and hospital incident command / crisis cell.
- Implement risk-based isolation of the imaging network and block unnecessary administrative pathways.
- Define a clinical safety exception process for critical connectivity.
- Begin enterprise-wide scoping: EDR queries, firewall logs, lateral movement indicators, affected subnet inventory.
- Engage PACS/radiology vendors, biomedical engineering, privacy/legal, communications, and executive leadership.

Facilitator Notes

Ensure participants do not assume the crisis cell tells SOC exactly which cables to pull. Technical teams recommend and execute containment; crisis leadership sets business and patient-safety priorities.

Inject 4: Patient Care Escalation

Time	Situation update
T+5:00 / 13:15	Emergency department leadership considers diverting trauma patients to nearby hospitals because urgent imaging availability is unreliable.

Discussion Questions

- What criteria trigger trauma diversion or service limitation?
- Who approves diversion, and who must be notified externally?
- How will patients already in the ED, inpatient units, and surgical pipeline be triaged?
- What public, patient, or media statement is appropriate if ambulance diversion becomes visible?
- What privacy/regulatory assessment is required if malware is confirmed but data exfiltration is unknown?

Expected Actions / Good Practice Indicators

- Convene patient-safety leadership and document diversion decision criteria.
- Notify regional emergency medical services, partner hospitals, transfer center, and health-system leadership as required.
- Establish clinical prioritization rules and status updates at fixed intervals.
- Prepare approved internal and external communications with legal/privacy review.

- Continue breach assessment, log preservation, malware containment, and recovery planning.

Facilitator Notes

Challenge teams to state exact thresholds: number of unavailable scanners, turnaround times, trauma/stroke impact, and staffing constraints.

7. Key Decision Points

Decision	Recommended decision criteria	Primary owner(s)
Endpoint isolation	Suspicious script execution, unknown attachment provenance, EDR confidence, lateral movement risk.	SOC / IT Security
Clinical downtime activation	PACS access instability, scanner workstation reboots, delayed urgent reads, patient safety risk.	Radiology leadership / Incident Command
Imaging network containment	Malware confirmed on imaging-connected hosts, segmentation uncertainty, risk of spread to modalities/PACS.	SOC / Network / Clinical Engineering
Patient diversion	Inability to support trauma/stroke or critical imaging within safe timeframes; lack of safe workaround capacity.	Hospital Incident Command / ED Leadership
Regulatory notification	Confirmed service disruption, patient-care impact, suspected breach of PHI, local reporting thresholds.	Privacy / Legal / Compliance
Safe restoration	Eradication confidence, clean backups/images, segmentation fixes, clinical validation, vendor confirmation.	Incident Commander / IT / Clinical Owners

8. Technical and Business Impacts

Impact area	Likely impact	Exercise prompts
Clinical care	Delayed CT/MRI/X-ray workflows; unreliable results access; potential ED and surgical delays.	How are urgent exams prioritized and tracked?
IT operations	Containment may require network isolation and temporary loss of administrative connectivity.	What connectivity is essential and who approves exceptions?
Security response	Malware scoping, endpoint isolation, lateral movement review, segmentation validation.	How is evidence preserved while restoring care?
Privacy/legal	Potential PHI exposure unknown during early response; notification thresholds require assessment.	What facts are needed for breach determination?
Reputation	Media, patient, and partner concern if diversion occurs or services are unavailable.	Who approves patient-facing and media statements?

9. Facilitator Guide

Recommended Flow

- Opening and rules of engagement: 10 minutes.
- Scenario context and roles: 10 minutes.
- Inject 1 discussion: 10 minutes.
- Inject 2 discussion: 15 minutes.
- Inject 3 discussion: 20 minutes.
- Inject 4 discussion: 20 minutes.

- Debrief, observations, and action capture: 15 minutes.

Facilitation Tips

- Ask participants to state role, decision, rationale, owner, and next communication after each major answer.
- Capture unclear authority, missing contacts, untested workarounds, and ambiguous notification thresholds as improvement items.
- Avoid solving every technical detail; keep focus on coordination and decision quality.
- Use time pressure when participants delay patient-care decisions awaiting perfect technical certainty.

Observer Evaluation Criteria

- Escalation was timely and based on defined severity and patient-care impact.
- Clinical downtime procedures were activated using clear criteria.
- Containment balanced patient safety with cyber risk.
- Communications were accurate, role-based, and approved by appropriate owners.
- Evidence preservation and restoration controls were considered before systems were rebuilt or reconnected.
- Regulatory and privacy obligations were identified early, even if final notification decisions depended on later facts.

10. Debrief and Lessons Learned

Use the final debrief to identify concrete actions, owners, and target dates. The scribe should capture both strengths and gaps.

- What worked well in the first 30 minutes of the response?
- Where did escalation or ownership become unclear?
- Were clinical downtime workflows detailed and practical enough?
- Could the hospital maintain safe care while isolating imaging systems?
- What evidence, logs, or asset data were missing?
- Were communications coordinated across technical, clinical, executive, and external stakeholders?
- Which corrective actions should be tracked through governance?

Suggested Improvement Backlog

- Validate segmentation between administrative workstations and clinical imaging networks.
- Run a separate technical exercise on PACS/modality isolation and restoration sequencing.
- Update radiology downtime procedures with specific triggers, owners, and communication templates.
- Review macro/script controls, email attachment protections, and PowerShell logging.
- Confirm EDR coverage for imaging workstations and biomedical/clinical endpoints.
- Define ambulance diversion criteria for cyber-driven diagnostic imaging outages.
- Create privacy/legal decision tree for malware events with uncertain PHI exposure.

11. MITRE ATT&CK Mapping

The STIX bundle explicitly identifies user execution of a malicious attachment as ATT&CK technique T1204. The scenario also implies several related techniques based on the described PowerShell activity, malware execution, and spread through poorly segmented networks; these should be validated during technical planning before use as

detection requirements.

Tactic	Technique	ID	Scenario reflection
Execution	User Execution: Malicious File / Attachment	T1204 / T1204.002	Radiology scheduling clerk opens an invoice attachment that initiates suspicious activity.
Execution	Command and Scripting Interpreter: PowerShell	T1059.001	Endpoint monitoring detects suspicious PowerShell activity after attachment execution.
Defense Evasion	Impair Defenses / Obfuscated or Suspicious Script Activity	T1562 / T1027 (plausible)	Facilitator may introduce questions about whether controls detected, blocked, or logged the scripts.
Lateral Movement	Lateral Tool Transfer / Remote Services (plausible)	T1570 / T1021	Malware spreads through segmentation gaps from administrative systems toward imaging-connected hosts.
Impact	System Shutdown/Reboot and Service Disruption	T1529 / T1489 (plausible)	CT and MRI workstations reboot unexpectedly; PACS viewer access becomes unreliable.
Impact	Data Encrypted for Impact (optional escalation)	T1486	Not asserted in the STIX bundle; optional future inject if ransomware behavior is added.

Appendix A: Glossary

- CT: Computed tomography.
- ED: Emergency department.
- EDR: Endpoint detection and response.
- IR: Incident response.
- MRI: Magnetic resonance imaging.
- PACS: Picture archiving and communication system used to store and access medical images.
- PHI: Protected health information.
- SOC: Security Operations Center.
- TTX: Tabletop exercise.